

WEB APPLICATION PENETRATION TEST REPORT

DVWA — Damn Vulnerable Web Application Assessment

Prepared by: Ekene Henry Uwaezuoke

Role: SOC Analyst & Penetration Tester

Date: 2026-06-25

Classification: CONFIDENTIAL

1. Executive Summary

A comprehensive web application penetration test was conducted against DVWA (Damn Vulnerable Web Application) to identify and exploit common web vulnerabilities. The assessment identified 6 critical and high severity vulnerabilities including SQL Injection, Cross-Site Scripting, Remote Code Execution via File Upload, Command Injection, Brute Force, and Stored XSS. All findings are documented with CVSS scores, MITRE ATT&CK; mappings, and remediation recommendations.

2. Scope & Methodology

Item	Details
Target Application	DVWA (Damn Vulnerable Web Application)
Target URL	http://127.0.0.1:42001 [LAB ENVIRONMENT]
Testing Type	Black Box / Gray Box Web Application Pentest
Tools Used	Nmap, Nikto, Hydra, Manual Testing
Test Date	2026-06-25
Tester	Ekene Henry Uwaezuoke

3. Findings Summary

#	Vulnerability	Severity	CVSS	MITRE ATT&CK
F-01	SQL Injection	CRITICAL	9.8	T1190

F-02	Remote Code Execution (File Upload)	CRITICAL	9.9	T1505.003
F-03	Command Injection	CRITICAL	9.8	T1059.004
F-04	Stored XSS	HIGH	8.8	T1059.007
F-05	Reflected XSS	HIGH	6.1	T1059.007
F-06	Brute Force — No Lockout	HIGH	7.5	T1110
F-07	Missing Security Headers	MEDIUM	5.3	T1562
F-08	Database Port 3306 Exposed	HIGH	7.5	T1190

4. Detailed Findings

F-01: SQL Injection

Description: The application is vulnerable to SQL injection allowing extraction of all database records including usernames and password hashes.

Payload used: 1' UNION SELECT user,password FROM users-- -

CVSS Score: 9.8 (CRITICAL)

MITRE ATT&CK;: T1190 — Exploit Public-Facing Application

Impact: Full database compromise. All user credentials exposed.

Remediation: Use prepared statements and parameterized queries. Implement input validation. Use WAF.

F-02: Remote Code Execution via File Upload

Description: The file upload function accepts PHP files allowing upload and execution of a web shell.

Shell uploaded: shell.php containing system() function

Command executed: whoami returned '_dwwa'

CVSS Score: 9.9 (CRITICAL)

MITRE ATT&CK;: T1505.003 — Web Shell

Impact: Full server compromise. Attacker can execute any OS command.

Remediation: Validate file types server-side. Whitelist allowed extensions. Store uploads outside web root.

F-03: Command Injection

Description: The ping functionality allows injection of OS commands via semicolon separator.

Payload: 127.0.0.1; cat /etc/passwd

CVSS Score: 9.8 (CRITICAL)

MITRE ATT&CK;: T1059.004 — Unix Shell

Impact: Full OS command execution. System files accessible.

Remediation: Never pass user input directly to OS commands. Use allowlist validation.

F-04: Stored XSS

Description: Malicious scripts can be permanently stored in the database and executed in every visitor's browser.

Payload: <script>alert('Stored XSS by Henry')</script>

CVSS Score: 8.8 (HIGH)

MITRE ATT&CK;: T1059.007 — JavaScript

Impact: Session hijacking, credential theft, malware distribution.

Remediation: Encode all output. Implement Content Security Policy (CSP). Sanitize input.

F-05: Reflected XSS

Description: User input is reflected in the response without sanitization allowing script injection.

Payload: <script>alert('XSS')</script>

CVSS Score: 6.1 (HIGH)

MITRE ATT&CK;: T1059.007 — JavaScript

Impact: Phishing, session theft via malicious links.

Remediation: Sanitize and encode all user input before reflecting in response.

F-06: Brute Force — No Account Lockout

Description: The login form has no account lockout or rate limiting allowing unlimited password attempts.

Tool used: Manual testing with admin/password credentials

CVSS Score: 7.5 (HIGH)

MITRE ATT&CK;: T1110 — Brute Force

Impact: Attacker can guess passwords without restriction.

Remediation: Implement account lockout after 5 failed attempts. Add CAPTCHA. Enable MFA.

5. Conclusion

The web application assessment revealed multiple critical and high severity vulnerabilities that would allow a real attacker to fully compromise the application and underlying server. Three critical findings (SQL Injection, RCE via File Upload, and Command Injection) require immediate remediation. All findings have been documented with CVSS scores, MITRE ATT&CK; mappings, proof of concept evidence, and actionable remediation guidance.

Report prepared by: Ekene Henry Uwaezuoke

SOC Analyst & Penetration Tester

Portfolio: bihghefty.github.io/cyberportfolio